

Course End Project-
Application Security, Vulnerability Management, and Cyber Resilience

Securing the Digital Marketplace: Strengthening Security for Vulnerable Websites

By

Sharmila Vijayan

1. Introduction:

Before launching its new website, the e-commerce business performs security testing to detect critical vulnerabilities. Using **Burp Suite**, ethical hackers identify issues such as SQL Injection, Cross-Site Scripting (XSS), broken access controls, and insecure APIs. These findings help the development team fix security flaws and strengthen the platform before release.

2. Problem Statement:

During the testing phase, ethical hackers simulated real-world attacks using industry-standard tools such as Nmap and Burp Suite. The assessment revealed severe vulnerabilities including SQL injection, Cross-Site Scripting, broken access controls, insecure APIs, and exposed sensitive data. These weaknesses posed significant risks, such as unauthorized admin panel access, session hijacking, and potential financial fraud through flaws like expired coupon validation.

3. Project Objective:

The objective of this project is to conduct a comprehensive security assessment of the e-commerce website before its launch to identify and mitigate critical vulnerabilities such as SQL Injection (SQLi), Cross-Site Scripting (XSS), broken access controls, and insecure APIs. By simulating real-world cyberattacks using **Burp Suite**, the goal is to evaluate the platform's security posture, prevent unauthorized access and data breaches, and ensure the implementation of strong input validation, secure coding practices, and robust access controls.

4. Scope of the Project:

The scope of this project includes performing a structured security assessment of the e-commerce website prior to its public launch. The testing focuses on identifying vulnerabilities such as SQL Injection (SQLi), Cross-Site Scripting (XSS), broken access controls, insecure APIs, session management flaws, and sensitive data exposure.

The project involves:

- Intercepting and analyzing web traffic with **Burp Suite**
- Testing authentication, authorization, and input validation mechanisms
- Evaluating risks related to admin panel access, session hijacking, and financial transactions
- Documenting vulnerabilities and recommending remediation measures
- Verifying security improvements through re-testing after fixes are implemented

The scope is limited to ethical testing within the authorized testing environment and does not involve live production systems or real customer data.

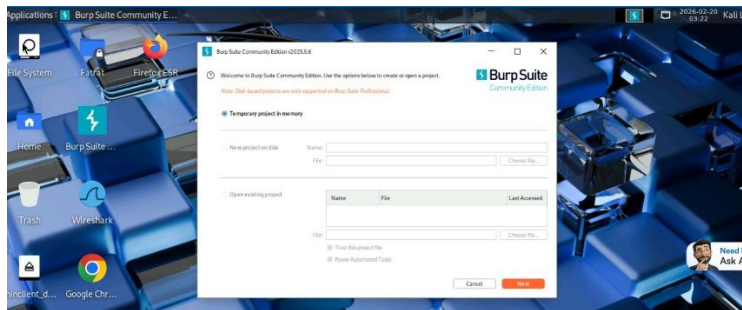
5. Implementation Details:

1. Intercepting and Manipulating HTTP Requests.
2. Exploiting Identified Vulnerabilities
3. Access control testing

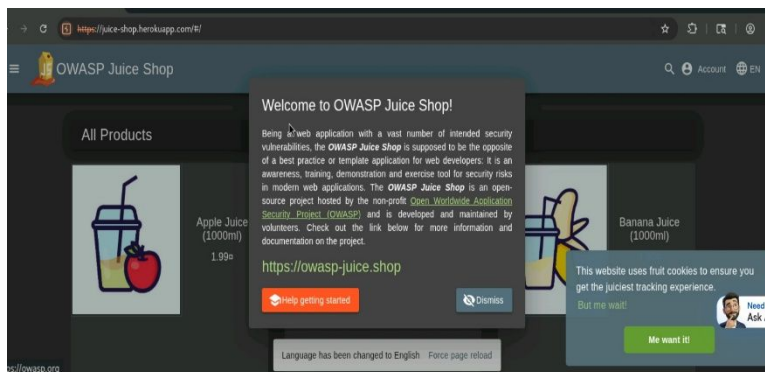
6. Steps to be followed to achieve the results:

Step 1: Intercepting and Manipulating HTTP Requests

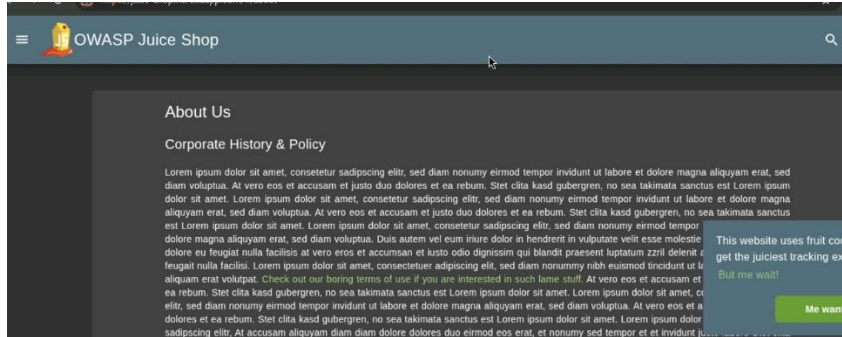
1.1 Navigate to KALIVM-1882823 and open Burp Suite.



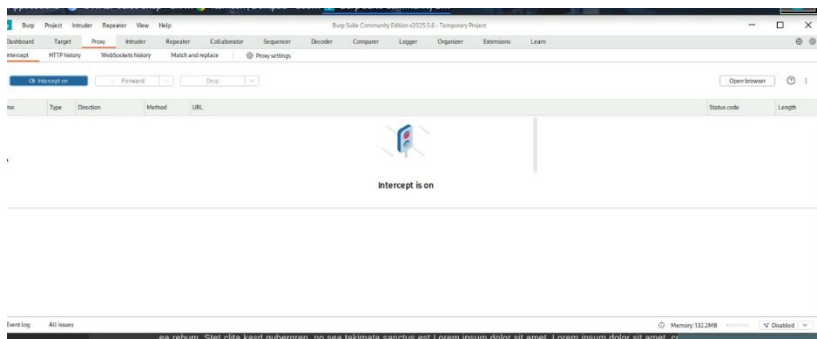
1.2 Click Start Burp Open Click Proxy > Open browser. Enter the URL <https://juice-shop.herokuapp.com/#/>



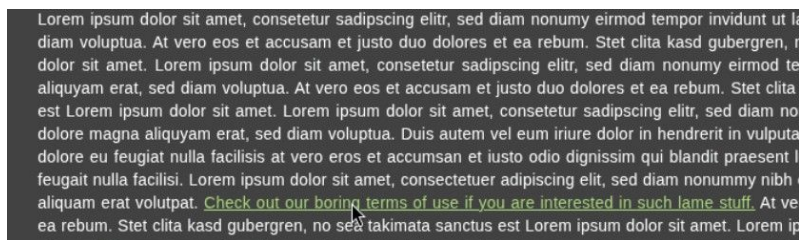
1.3 Click the three horizontal lines in the top-left corner to open the side menu. Click About Us.



1.4 Navigate to Burp Suite and Click to turn the Intercept on.

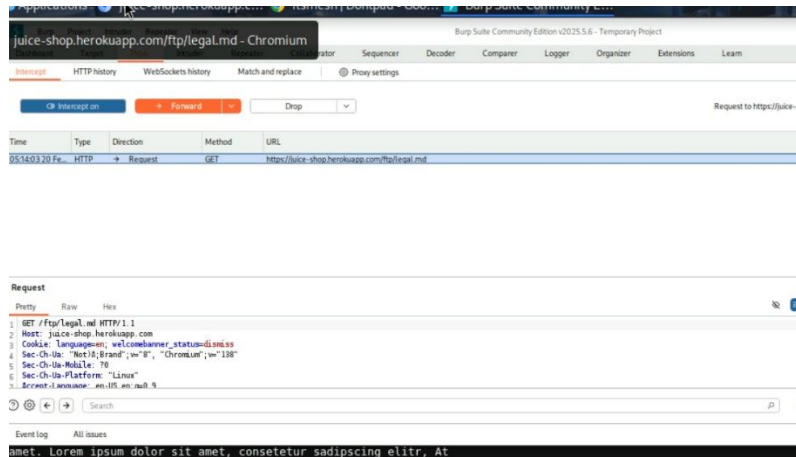


1.5 Navigate back to the OWASP Juice Shop page and click Check out our boring terms of use if you are interested in such lame stuff.

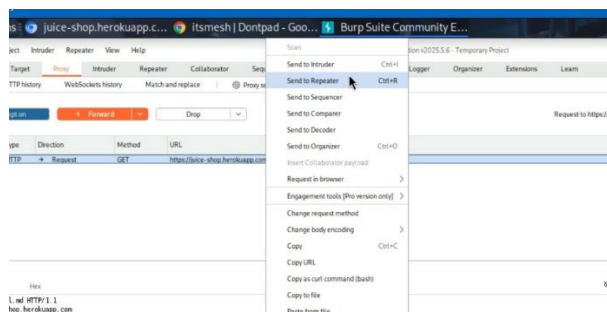


1.6 Navigate back to Burp Suite and repeatedly click the Forward button until you see the request

GET /ftp/legal.md HTTP/1.1

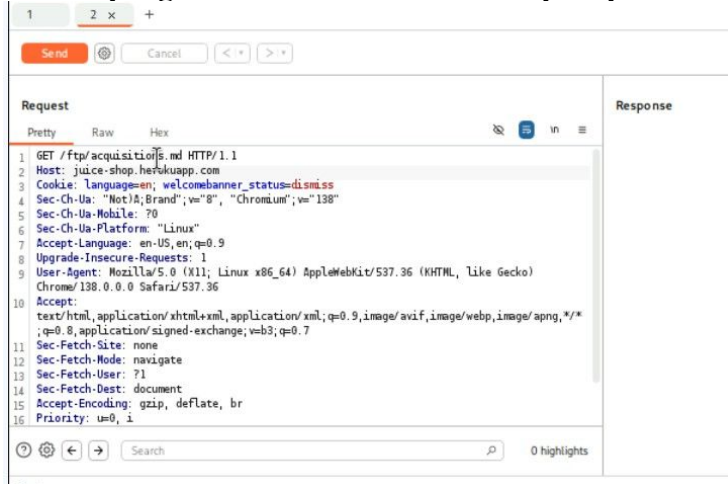


1.7 Right-click the blank-space and click Send to Repeater

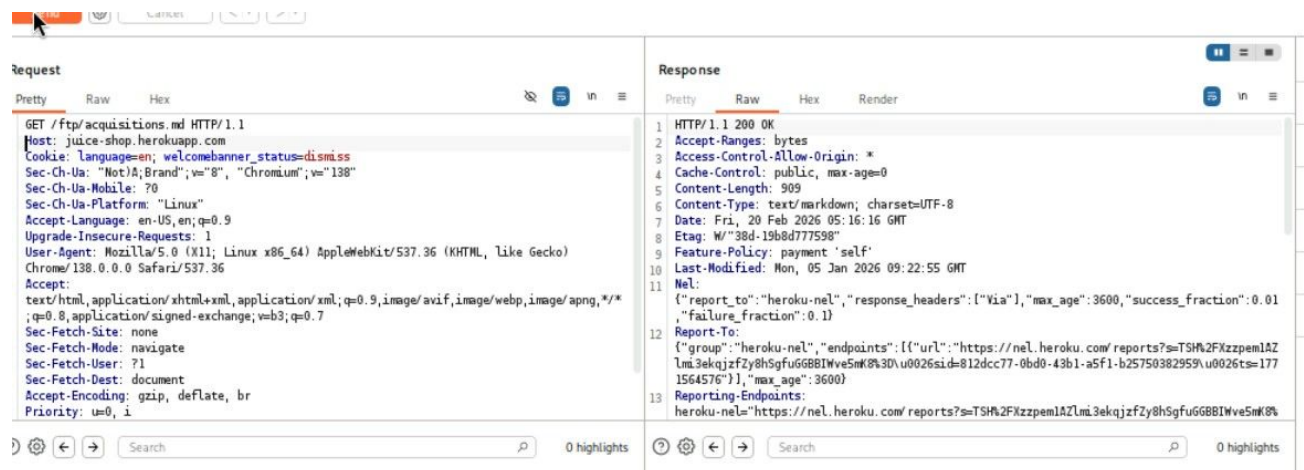


1.8 Click the Repeater tab, modify the request line as below.

GET /ftp/legal.md HTTP/1.1 to GET /ftp/acquisitions.md HTTP/1.1



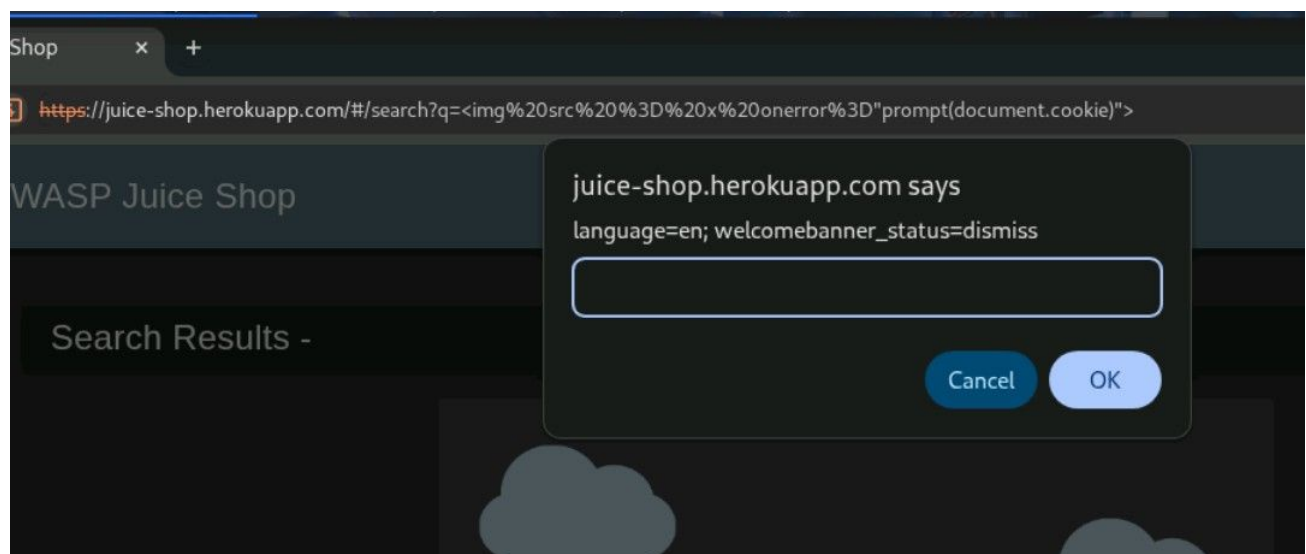
1.9 Click Send to execute the request.



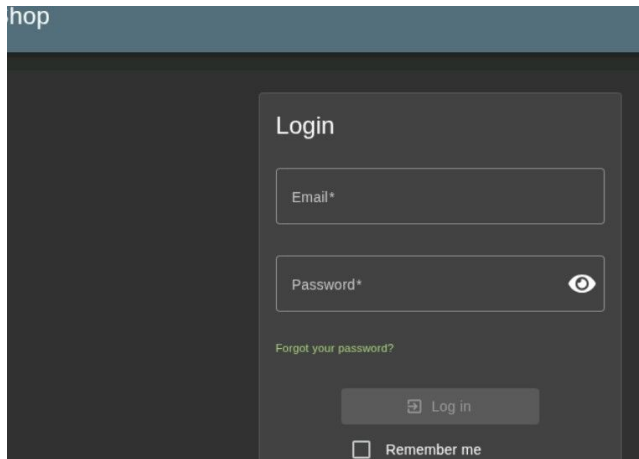
Step 2: Exploit and test the vulnerabilities found

2.1 Navigate back to the OWASP Juice Shop home page and click the search icon
Type the following command and press the enter key:

```
<img src = x onerror="prompt(document.cookie)">
```



2.2 Navigate back to the OWASP Juice Shop page, click Account, and then click Login

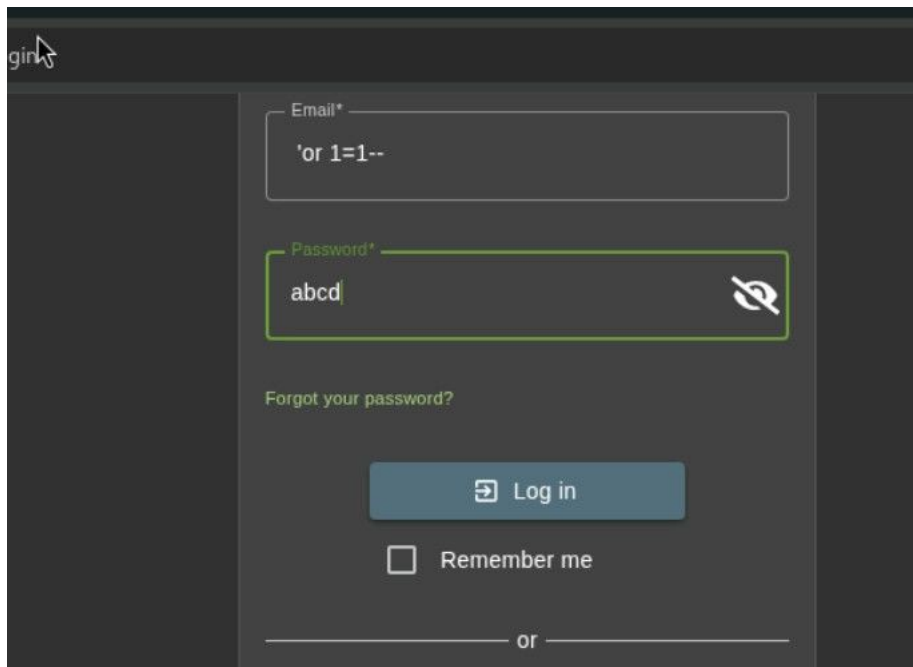


The screenshot shows the 'Login' form on the OWASP Juice Shop page. The form is centered on a dark background. It includes a 'Login' title, an 'Email*' input field, a 'Password*' input field with a toggle icon, a 'Forgot your password?' link, a 'Log in' button, and a 'Remember me' checkbox.

2.3 Enter the following credentials to perform SQL injection and click Log in:

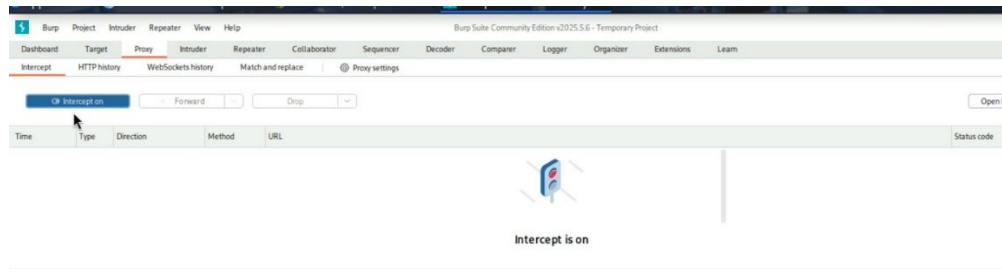
Email: 'or 1=1--

Password: abcd



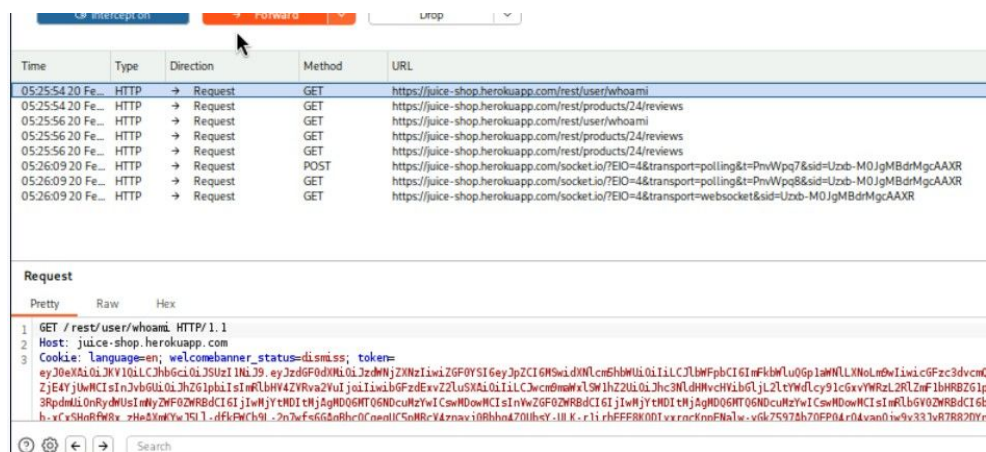
The screenshot shows the 'Login' form with the SQL injection credentials entered. The 'Email*' field contains the text 'or 1=1--' and the 'Password*' field contains the text 'abcd'. The 'Log in' button is highlighted with a blue border. The 'Remember me' checkbox is unchecked. The 'Forgot your password?' link is visible below the password field.

2.5 Navigate back to Burp Suite and turn on the Intercept button

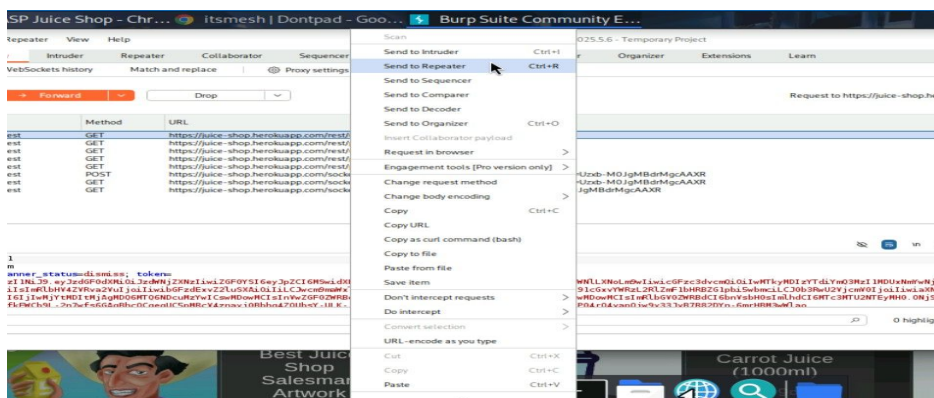


2.6 Navigate back to OWASP Juice Shop page and click any product.

2.7 Click Forward repeatedly till you see GET /rest/user/whoami HTTP/1.1



2.8 Right click the blank-space and click Send to Repeater



Privacy Policy

Effective date: March 15, 2019

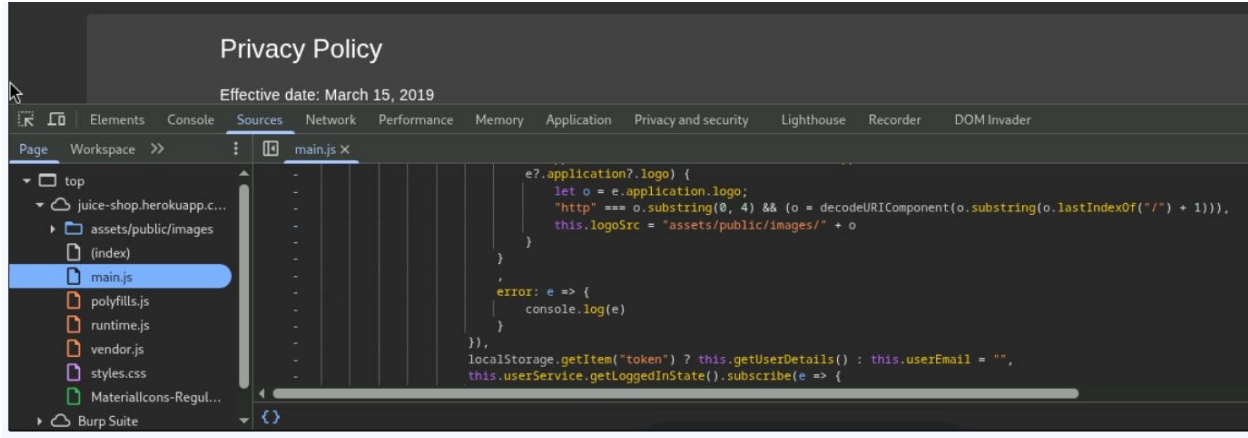
OWASP Juice Shop ("us", "we", or "our") operates the <https://juice-shop.herokuapp.com> website (the "Service").

This page informs you of our policies regarding the collection, use, and disclosure of personal data when you use our Service and the choices you have associated with that data. Our Privacy Policy for OWASP Juice Shop is created with the help of the [Free Privacy Policy website](#).

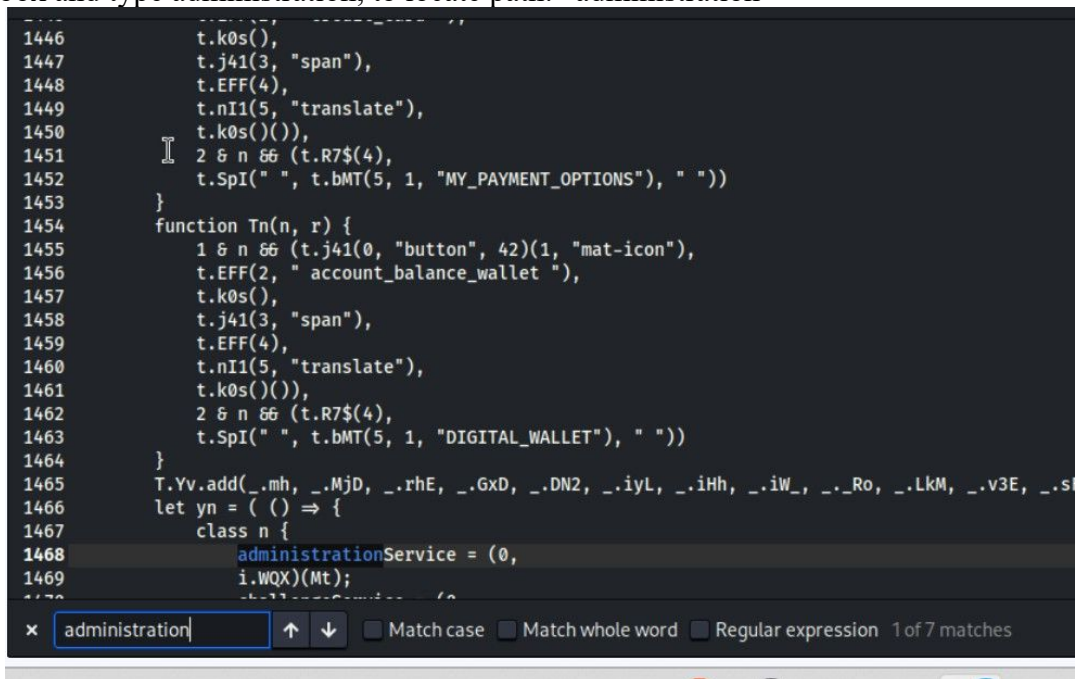
We use your data to provide and improve the Service. By using the Service, you agree to the collection and use of information as described in this Privacy Policy. The terms and conditions of the Service, as well as the terms and conditions of the [OWASP Juice Shop](#), apply to the use of the Service. The terms and conditions of the Service, as well as the terms and conditions of the [OWASP Juice Shop](#), apply to the use of the Service.

A. Information Collection And Use

2.12 Right-click the blank space and click Inspect. Click Sources and select main.js

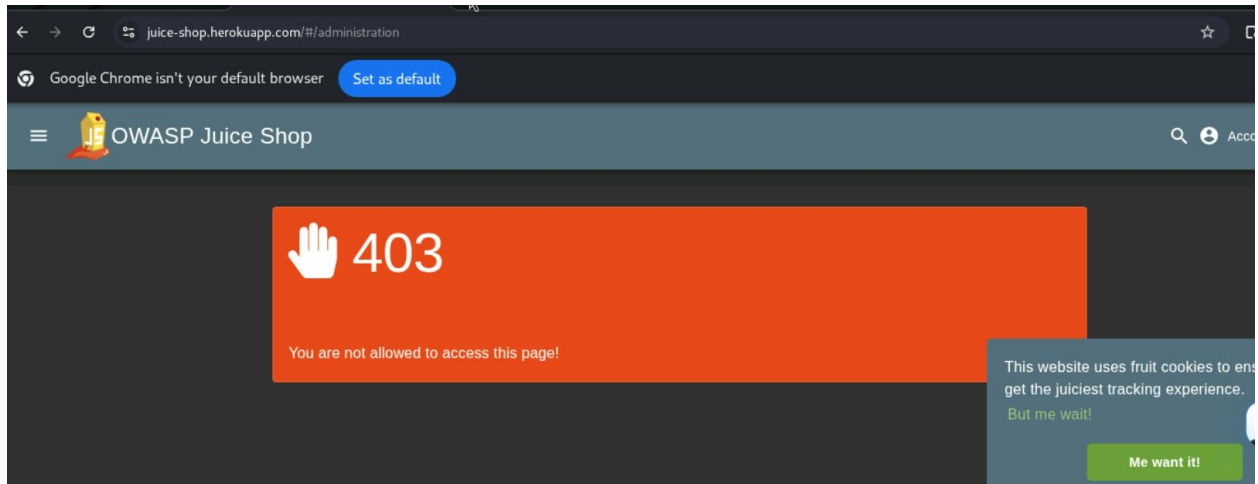


2.14 Select the entire code and copy . Click Editor > Paste the entire code in the editor .Click the search box and type administration, to locate path: “administration”



2.17 Open the following URL:

<https://juice-shop.herokuapp.com/#!/administration>



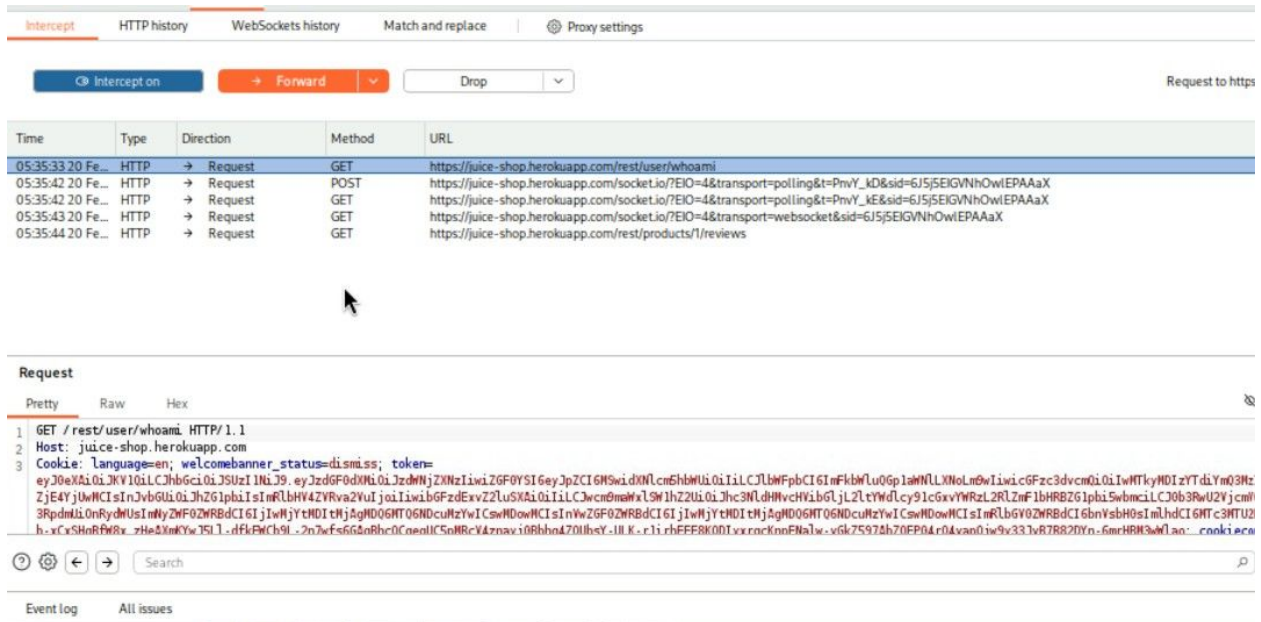
Step 3: Access control testing

3.1 Navigate back to the OWASP Juice Shop page

3.2 Navigate to Burp Suite and Click Intercept on

3.3 Select a product

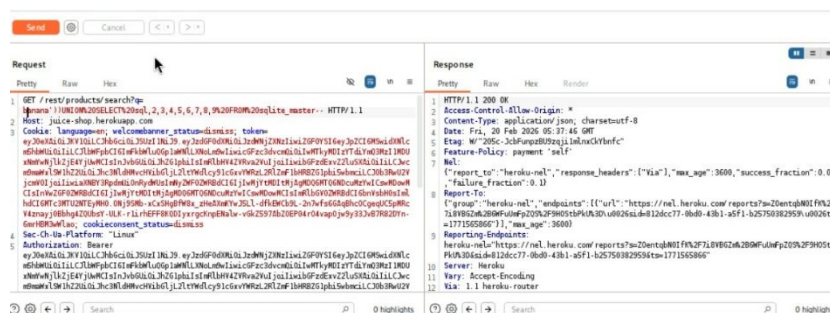
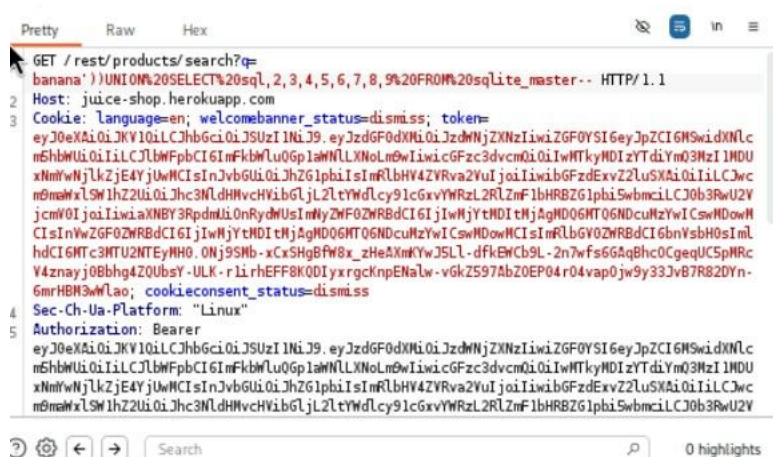
3.4 Navigate to Burp Suite. Click Forward repeatedly till you see GET /rest/user/whoami HTTP/1.1



3.5 Right-click the blank-space and click Send to Repeater

3.6 Type the following command to replace the request-line and Click Send.

**GET/rest/products/search?q=banana'))UNION%20SELECT%20sql,2,3,4,5,6,7,8,9
%20FROM%20sqlite_master-- HTTP/1.1**

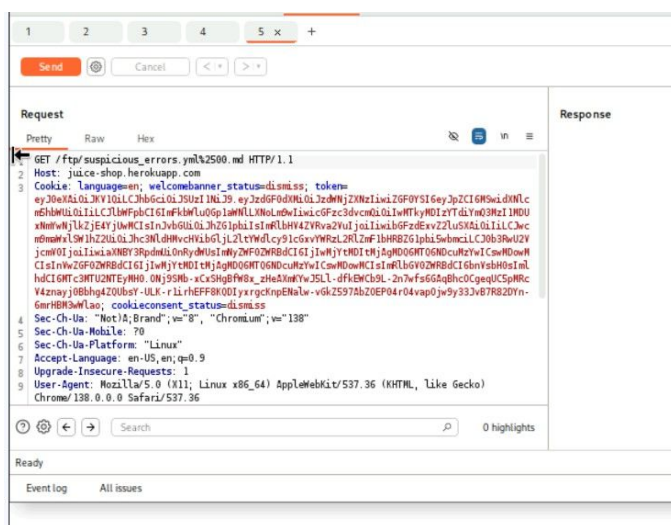


3.7 Navigate back to the OWASP Juice Shop page and click the three horizontal lines. Click About Us

3.8 Go back to Burp Suite and click Intercept is on

3.9 Click Check out our boring terms of use if you are interested in such lame stuff

3.10 Click Forward repeatedly till you see GET /ftp/legal.md HTTP/1.1



3.11 Right-click the blank-space and click Send to Repeater

3.12 Click Repeater

```
GET /ftp/suspicious_errors.yml%2500.md HTTP/1.1
```



Conclusion:

This project successfully demonstrated the importance of proactive security testing in protecting e-commerce platforms from critical cyber threats. Through controlled ethical hacking using industry-standard tools such as Burp Suite and simulated attack techniques on **OWASP Juice Shop**, multiple high-risk vulnerabilities were identified, including SQL Injection (SQLi), Cross-Site Scripting (XSS), broken access controls, insecure APIs, and sensitive data exposure.

Findings and Recommendations:

1. Sensitive Data Exposure

Details: Sensitive files (e.g., /ftp/legal.md and /ftp/acquisitions.md) were accessible without proper authentication.

Exploitation: An attacker could access sensitive business documents using tampered HTTP requests.

Recommendation: Implement access control policies to restrict unauthorized access to sensitive files. Use directory-level authentication or token-based access for protected resources.

2. Cross-Site Scripting (XSS)

Details: The search field was vulnerable to XSS. Executing the payload `<img src=x onerror=prompt(document.cookie)>` triggered a popup, confirming the vulnerability.

Exploitation: Malicious actors could steal cookies or inject harmful scripts.

Recommendation: Sanitize user inputs by validating and encoding special characters. Use a Content Security Policy (CSP) to mitigate the impact of XSS attacks.

3. SQL Injection (SQLi)

Details: The login page accepted SQL payloads (e.g., `' or 1=1 --`), allowing attackers to bypass authentication and log in as an admin.

Exploitation: Exploited to gain admin privileges and extract sensitive database information.

Recommendation: Use parameterized queries and prepared statements to prevent SQL injection. Validate and sanitize user inputs.

4. Poor Error Handling

Details: Changing API endpoints (e.g., /rest/user/whoami to /rest/tomato) resulted in internal server errors, revealing implementation details.

Exploitation: Leaked server information could aid attackers in crafting more targeted attacks.

Recommendation: Implement proper error handling mechanisms. Display generic error messages to users while logging detailed errors on the server side.

In conclusion, security must be integrated into every phase of the software development lifecycle rather than treated as an afterthought. Regular penetration testing, continuous monitoring, and adherence to security best practices ensure that digital marketplaces remain secure, trustworthy, and resilient against evolving cyber threats.

References:

1. Application Security, Vulnerability Management, and Cyber Resilience course CEP session by Walter

Thank You